

Penetration Testing



Alfred Mandl
alfred.mandl@fhv.at

- ◆ Introduction to Security Testing
- ◆ Practical Security Testing using the example of Penetration Test (methodology and tools)
 - Footprinting
 - Scanning
 - Analysis of scanning results
 - Finding and exploiting vulnerabilities

- ◆ You know one prominent security testing type – penetration tests
- ◆ You have learned the basics to perform a test yourself
- ◆ You know the methodology and tools used during a penetration test
- ◆ You know what information the tools can deliver



INTRODUCTION TO SECURITY TESTING

- ◆ **Security Testing** means testing an environment (e.g. a specific application) for the presence of security-relevant problems
 - Misconfigurations, outdated (unpatched software), implementation flaws ...
 - It's basically similar to „normal“ software testing and uses a combination of manual methods and tool support
 - Just like „normal“ software testing, security testing can only show the presence of defects, but never prove the absence of defects
- ◆ The **goal of security** testing is to uncover as many security-relevant defects as possible
 - Based on the findings, the tested environment should be fixed ...
 - ... which hopefully means the security will be improved ...
 - ... because there are fewer attack vectors an attacker can exploit
- ◆ The **effort spent in security testing** should be reasonable compared to the value of the target for an attacker

- ◆ There are **various methods** to perform a security test:
 - Architecture/design/processes review
 - Source code analysis
 - Searching for public available sensitive information
 - Automated security scans
 - Hand-on assessment using manual and semi-automated methods
 - ...

- ◆ Tests are also often identified as **black-, white- or grey-box tests**
 - Means that the tester has no / full / partial knowledge about the environment to test

- ◆ Usually, security testing consists of a **combination of methods**
 - Make sure to define the scope of a security test beforehand
 - This is especially important if you offer this as a commercial service

- ◆ One prominent type of security test is a **penetration test**
 - Analyses an IT-environment and searches for exploitable vulnerabilities
 - It „simulates“ the behavior of an attacker
 - The effort spent is an indication of the effort an attacker would have to spend to achieve the same result (i.e. to uncover vulnerabilities)

- ◆ **Phases of a penetration test**
 1. **Preparation phase**
 - define scope (not discussed here)
 2. **Footprinting**
 - collecting relevant information about the target environment
 3. **Scanning**
 - Examine the target networks and hosts in more detail
 4. **Analysis of scanning results**
 - Identify the systems that one will attempt to compromise during the following phase
 5. **Finding and exploiting vulnerabilities**
 - Identify vulnerable systems and demonstrate proof-of-concept or „real“ exploits
 6. **Reporting**
 - Prepare a written report and an oral presentation (not discussed here), including concrete recommendations

FOOTPRINTING



- ◆ Footprinting means **collecting relevant information** of the target and generating a profile of the target's Internet / Intranet presence
- ◆ Footprinting is the **first step** an attacker or security tester performs when attacking / analyzing a target
- ◆ The necessary footprinting **activities** depend on how much information is already available or how focused the analysis should be
 - One extreme is starting with a company name only
 - The other extreme is being restricted to a specific set of IP addresses from the beginning and having detailed information about the systems
- ◆ **What information** are we interested in?
 - Domain names, IP address blocks, contact persons
 - Interesting systems (hostnames, IP addresses), internal system configurations

Footprinting – Getting Domain Names

- ◆ The first thing to do is getting the **domain name(s)** of the company
- ◆ This can be easily achieved using any **search engine**
 - [Google](#), [robtex](#)
 - Do not only looking at the first entry, maybe there are **additional domains** available/used for a company name

Base	Record	Name	IP	Reverse	Route	AS
fhv.at	a		193.170.2.230 Austria	web.uclv.net	193.170.0.0/15 ACOnet, Provider Local Registry Block	AS1853 ACOnet Backbone AT
			2001:628:2130:3000::80:1	(none)		?
	ns-soa	ns1.uclv.net	193.170.2.142 Austria		193.170.0.0/15 ACOnet, Provider Local Registry Block	AS1853 ACOnet Backbone AT
			2001:628:2130:3000::53:1	(none)		?
	ns	ns1.uclv.net	193.170.2.142 Austria		193.170.0.0/15 ACOnet, Provider Local Registry Block	AS1853 ACOnet Backbone AT
			2001:628:2130:3000::53:1	(none)		?
	mx	mx1.uclv.net	193.170.2.222 Austria		193.170.0.0/15 ACOnet, Provider Local Registry Block	AS1853 ACOnet Backbone AT
				(none)		?

Fachhochschule Vorarlberg GmbH

Ungefähr 1.060.000 Ergebnisse (0,15 Sekunden)

Fachhochschule Vorarlberg GmbH

[www.fhv.at/](#)

Informationen über Studiengänge, Weiterbildungsangebote, Forschungsvorhaben und internationale Aktivitäten.

2 Google-Bewertungen · Bericht schreiben

Hochschulstraße 1 6850 Dornbirn 05572 7920

Bachelor-Studium

Info. Alle Bachelor-Studiengänge. An der FH Vorarlberg werden 9 ...

FHV Inside

Information Services führt derzeit eine schrittweise Integration der ...

Wohnungsbörse

English · Deutsch. RSS · Download · Bibliothek ...

FHV Studium

16 Studiengänge (9 Bachelor-Studiengänge und 7 Master ...

Kontakt

kontakt. FH Vorarlberg. Hochschulstraße 1. 6850 ...

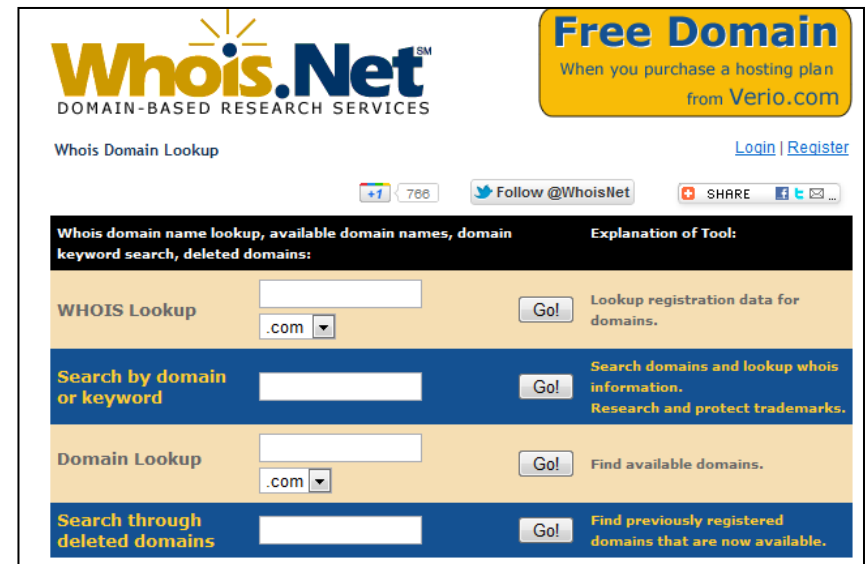
Anmelden

Studium, Forschung und Weiterbildung an der ...

Weitere Ergebnisse von fhv.at »

- 11 -

- ◆ When the domain name is known, the Whois service can be used to get additional details
 - Whois is a distributed service and there are various possibilities to query for information
 - Command line client
 - Simple to use
 - Primarily available for *ix systems
 - Commercial and free web front-ends
 - Also easy to use, but not always accurate/complete



The screenshot displays the Whois.Net website, which offers domain-based research services. The header includes the logo and a promotional banner for Verio.com. Below the header, there are social media links and a 'Whois Domain Lookup' section. The main content area features four distinct search tools, each with a text input field, a dropdown menu for domain extensions, and a 'Go!' button. The tools are: WHOIS Lookup, Search by domain or keyword, Domain Lookup, and Search through deleted domains. Each tool has a corresponding explanation of its function.

Whois domain name lookup, available domain names, domain keyword search, deleted domains:		Explanation of Tool:
WHOIS Lookup	Go!	Lookup registration data for domains.
Search by domain or keyword	Go!	Search domains and lookup whois information. Research and protect trademarks.
Domain Lookup	Go!	Find available domains.
Search through deleted domains	Go!	Find previously registered domains that are now available.

- ◆ Most reliable option: **directly querying** the Whois databases
 - Start with the database for the top level domains (TLD): whois.iana.org
 - **Query for a TLD** (e.g. at) and search for the authoritative registry

IANA WHOIS Service

The IANA WHOIS Service is provided using the WHOIS protocol on port 43. This web gateway will query this server and return the results. Accepted query arguments are domain names, IP addresses and AS numbers.

% IANA WHOIS server
% for more information on IANA, visit <http://www.iana.org>
% This query returned 1 object

domain: AT

organisation: **NIC.AT Internet Verwaltungs und Betriebsgesellschaft m.b.H**
address: Jakob-Haringer-Strasse 8
address: Salzburg A-5020
address: Austria

contact: administrative
name: Geschaeftsfuehrer NIC.AT
organisation: NIC.AT Internet Verwaltungs und Betriebsgesellschaft m.b.H.
address: Jakob-Haringer-Strasse 8
address: Salzburg A-5020
address: Austria
phone: +43 662 4669-14
fax-no: +43 662 4669-19
e-mail: gf@nic.at

- ◆ On <http://www.nic.at>, a Whois search for www.fhv.at can be performed to find details such as contact persons, name servers etc.



Whois / Domain Suche

Hier können Sie die Whois-Daten einer bestehenden Domain abrufen:

Domain
www.
[IDN Eingabehilfe](#)

Whois Ergebnis für Domain: fhv.at

Bei der Whois-Abfrage handelt es sich um eine urheberrechtlich geschützte Datenbank. Sämtliche Rechte insbesondere jene der Vervielfältigung stehen ausschließlich nic.at zu.

Domaininhaber:

Organisationsname: Fachhochschule Vorarlberg GmbH
Strasse: Hochschulstrasse 1
PLZ: A-6850
Stadt: Dornbirn
Land: AT
Telefonnummer: +435572792
Faxnummer: +4355727929500
E-Mail Adresse: christian.boesch@fhv.at
Personen Handle: FVG2483364-NICAT

Admin-C:

Organisationsname: Fachhochschule Vorarlberg GmbH
Strasse: Hochschulstrasse 1
PLZ: A-6850
Stadt: Dornbirn
Land: AT
Telefonnummer: +435572792
Faxnummer: +4355727929500
E-Mail Adresse: christian.boesch@fhv.at
Personen Handle: FVG2483364-NICAT

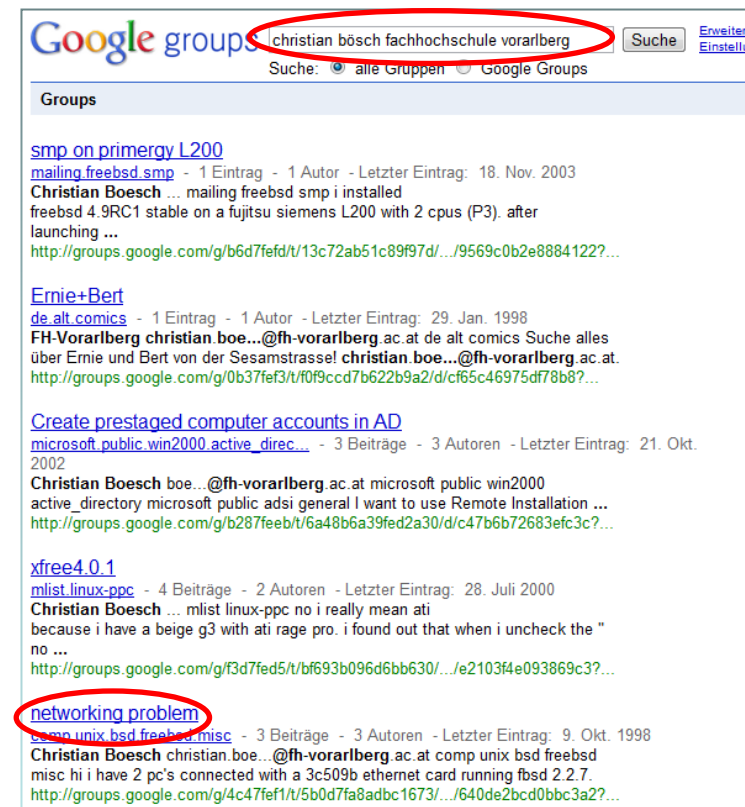
- ◆ The **company web sites themselves** can provide lots of interesting information, especially with respect to contact persons and their activities
- ◆ Example
 - Look for **search functions** and enter the contact information received by the Whois query



- So we have found additional information **valuable for social engineering attacks!**
 - He is **system administrator**
 - We know his **phone number** and **e-mail address**
 - We know **additional members** of FHV IT-services

Footprinting – Using Search Engines (1)

- ◆ Search engines – especially Google – are powerful tools to find security-relevant information about a company
 - Using appropriate search options can reveal desired results (e.g. inurl)
- ◆ The **Usenet** provides a wealth of information as well
 - ... and IT personnel needing answers often disclose **sensitive information**



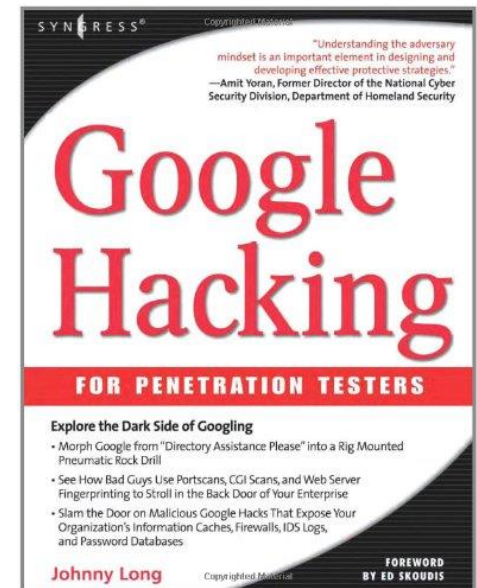
Footprinting – Using Search Engines (2)

- ◆ Google allows much more interesting searches, think about
 - password inurl:fhv.at
 - to get information about passwords
 - manual inurl:fhv.at
 - to get internal technical information
 - "vulnerability report" inurl:fhv.at
 - to get internal vulnerability reports (you never know ...)

- ◆ Even if the information may no longer be available on the website, it may be accessible through Google cache

- ◆ There's in fact an entire web site and a book dedicated to such searches, also known as Google Hacking (<http://johnny.ihackstuff.com/>)

- ◆ Foundstone made available the great SiteDigger tool, which automates Google hacking and which queries Google for interesting information
<http://www.mcafee.com/de/downloads/free-tools/sitedigger.aspx>



Footprinting – IP Range (1)

- ◆ Another question is the **IP range** used by the target company
 - IP ranges are assigned by the **Regional Internet Registries (RIR)**
 - ARIN for North America, RIPE for Europe etc.

```
root@debian:/# nslookup www.fhv.at
Server:      192.168.23.2
Address:     192.168.23.2#53

Non-authoritative answer:
www.fhv.at   canonical name = web.uclv.net.
Name:   web.uclv.net
Address: 193.170.2.230
```

- ◆ To search for the IP range of FHV, we just need one IP address of FHV

- Can be done by
 - performing an nslookup
 - Robtex
 - ...

Base	Record	Name	IP	Reverse	Route	AS
fhv.at	a		193.170.2.230 Austria 2001:628:2130:3000::80:1	web.uclv.net (none)	193.170.0.0/15 ACOnet, Provider Local Registry Block	AS1853 ACOnet Backbone AT
	ns-soa	ns1.uclv.net	193.170.2.142 Austria 2001:628:2130:3000::53:1	(none)	193.170.0.0/15 ACOnet, Provider Local Registry Block	AS1853 ACOnet Backbone AT
	ns	ns1.uclv.net	193.170.2.142 Austria 2001:628:2130:3000::53:1	(none)	193.170.0.0/15 ACOnet, Provider Local Registry Block	AS1853 ACOnet Backbone AT
		ns2.uclv.net	193.170.2.222 Austria	(none)	193.170.0.0/15 ACOnet, Provider Local Registry Block	AS1853 ACOnet Backbone AT
	mx	10 mx1.uclv.net		(none)		?
		10 mx2.uclv.net		(none)		?

- ◆ Entering this IP address at <http://www.ripe.net> ...

RIPE Database Search

193.170.2.142

By pressing the "Search" button you explicitly express your agreement with the RIPE Database Terms and Conditions.

Footprinting – IP Range (2)

- ◆ ... delivers the **information** (**IP range**) we are interested in

- And in addition further information about **contact persons**

This is the RIPE Database search service.
The objects are in RPSL format.
The RIPE Database is subject to Terms and Conditions.
See <http://www.ripe.net/db/support/db-terms-conditions.pdf>

```
inetnum: 193.170.2.0 - 193.170.2.255
netname: FH-VOR
descr: FH-Vorarlberg, Information Services
descr: Dornbirn
country: AT
admin-c: EN3
tech-c: EN3
status: ASSIGNED PA
mnt-by: ACONET-LIR-MNT
source: RIPE #Filtered

irt: IRT-ACONET-CERT
address: Vienna University Computer Center
address: Universitaetsstrasse 7
address: A-1010 Wien
address: Austria
phone: +43 1 427714045
fax-no: +43 1 42779140
abuse-mailbox: cert@aco.net
signature: PGPKEY-800559FB
encryption: PGPKEY-800559FB
admin-c: TI123-RIPE
tech-c: TI123-RIPE
auth: PGPKEY-800559FB
remarks: This is a TI accredited CSIRT/CERT
remarks: emergency phone number +43 1 427714045
remarks: timezone GMT+01 (GMT+02 with DST)
remarks: https://www.trusted-introducer.org/teams/aconet-cert.html
remarks: RFC-2350 service definition:
remarks: http://www.aco.net/rfc2350.html
irt-nfy: cert@aco.net
mnt-by: TRUSTED-INTRODUCER-MNT
source: RIPE #Filtered

person: Egon Niederacher
address: Fachhochschule Vorarlberg
address: Achstrasse 1
address: A-6850 Dornbirn
address: Austria
phone: +43 5572 20336 212
fax-no: +43 5572 26507
nic-hdl: EN3
mnt-by: ACONET-LIR-MNT
source: RIPE #Filtered
```

- ◆ Name servers contain **hostname to address mappings** for company computers
 - Querying this information tells a lot about used **hostnames, IP addresses and the purpose** of the corresponding hosts
- ◆ A good start is the **dig** command line tool (*ix)

```
;; flags: qr rd ra; QUERY: 1, ANSWER: 2, AUTHORITY: 2, ADDITIONAL: 4
;; QUESTION SECTION:
;www.fhv.at.                IN      A

;; ANSWER SECTION:
www.fhv.at.                 5       IN      CNAME   web.uclv.net.
web.uclv.net.               5       IN      A       193.170.2.230

;; AUTHORITY SECTION:
uclv.net.                   5       IN      NS      ns1.uclv.net.
uclv.net.                   5       IN      NS      ns2.uclv.net.

;; ADDITIONAL SECTION:
ns1.uclv.net.               5       IN      A       193.170.2.142
ns1.uclv.net.               5       IN      AAAA    2001:628:2130:3000::53:1
ns2.uclv.net.               5       IN      A       193.170.2.222
ns2.uclv.net.               5       IN      AAAA    2001:628:2130:3000::53:2

;; Query time: 7 msec
;; SERVER: 192.168.23.2#53(192.168.23.2)
;; WHEN: Wed Feb 15 14:02:38 2012
;; MSG SIZE rcvd: 194
```

- ◆ Knowing the IP range, one can easily automate the task to enumerate **hostname to address mappings** using inverse DNS lookups

- E.g. with <http://www.dnswatch.info/>
- Or Perl-Script for **class B (/16)** networks

```
Suche nach PTR Eintrag für 230.2.170.193.in-addr.arpa. bei K.ROOT-SERVERS.NET. [193.0.14.129] ...dauerte 17 ms
Suche nach PTR Eintrag für 230.2.170.193.in-addr.arpa. bei f.in-addr.servers.arpa. [193.0.9.1] ...dauerte 13 ms
Suche nach A Eintrag für ns3.univie.ac.at. bei J.ROOT-SERVERS.NET. [192.58.128.30] ...dauerte 12 ms
Suche nach A Eintrag für ns3.univie.ac.at. bei n.nic.at. [87.233.175.130] ...dauerte 13 ms
Suche nach A Eintrag für ns3.univie.ac.at. bei ns7.univie.ac.at. [193.171.23.114] ...dauerte 14 ms
Suche nach PTR Eintrag für 230.2.170.193.in-addr.arpa. bei ns3.univie.ac.at. [77.80.62.2] ...dauerte 13 ms
Suche nach A Eintrag für ns2.ucv.net. bei K.ROOT-SERVERS.NET. [193.0.14.129] ...dauerte 17 ms
Suche nach A Eintrag für ns2.ucv.net. bei e.gtld-servers.net. [192.12.94.30] ...dauerte 11 ms
Suche nach A Eintrag für ns2.ucv.net. bei ns2.ucv.net. [193.170.2.222] ...dauerte 27 ms
Suche nach PTR Eintrag für 230.2.170.193.in-addr.arpa. bei ns2.ucv.net. [193.170.2.222] ...dauerte 27 ms
```

Domain	Type	TTL	Answer
230.2.170.193.in-addr.arpa.	PTR	3600	web.ucv.net.

```
#!/usr/bin/perl

Use Socket;

$b_net = "160.85";

for ($i=0; $i<255; $i++) {
    for ($j=0; $j<255; $j++) {
        $ip = "$b_net.$i.$j";
        $ipaddr = inet_aton($ip);
        $name = gethostbyaddr($ipaddr, AF_INET);
        if ($name) {
            print "${ip}\t${name}\n";
        }
    }
}
```

- ◆ Footprinting is the **first step** performed by an attacker / security analyst
- ◆ After footprinting, you know **general, IT-related information** about the target company
 - Domain names
 - IP ranges
 - Technical contact persons
 - Hostnames and IP addresses of some systems
- ◆ If you are lucky, you have discovered **additional valuable information**
 - Critical information that has been voluntarily disclosed by the employees (internal system configurations etc.)
- ◆ There are **further information sources**
 - Social networks (Facebook, XING, ...), 123people, Blogs, Twitter, ...

SCANNING

Based on the footprinting result, the target company's network and hosts are **examined in more detail** during scanning

- ◆ Determine the **network structure**
 - Includes finding systems that are reachable from the attacker's / analyst's location (e.g. inside or outside the company)
- ◆ **Analyze the hosts** in detail
 - Identify operating systems and versions
 - Determine services running in the hosts and the corresponding software products
 - This can give hints at possible vulnerabilities present on a target system
- ◆ Perform **vulnerabilities scans**
 - To identify possible vulnerabilities on systems that may be exploited

- ◆ Determining the **network structure** is relevant when analyzing larger environments
 - It provides information about interesting "areas" (e.g. a DMZ) of a large network (which should be analyzed in detail during host scanning)
 - It may provide "**attack paths**" into the network, so even if a target system cannot be reached directly or does not offer interesting services to the outside, it may be reachable via other, maybe less protected systems
- ◆ Traditionally, **traceroute** is the tool of choice to analyze the network structure
 - **Lists all hops** (IP addresses) to the target system
 - There are different traceroute variants that either use **UDP or ICMP packets**
 - On *ix systems, UDP is usually the default and ICMP can be used with the **-I** option
 - It's often a good idea to **use both options**, especially if one is not successful

♦ Let's start with a traceroute to www.fhv.at

- Scan from external hosts
- Scan from internal hosts

```
root@debian:~# traceroute -q1 www.fhv.at
traceroute to www.fhv.at (193.170.2.230), 30 hops max, 60 byte packets
 1  192.168.23.2 (192.168.23.2)  0.225 ms
 2  *
 3  *
 4  *
 5  *
 6  *
```

- Also scan from internal to external

♦ Traceroute has its limits with firewalls that filter UDP or ICMP packets

- An asterisk indicates that no answer was received from the host
- So all we learn here is that "some filtering takes place"

- ◆ An even more flexible tool than traceroute is **hping3**
 - Allows to specify protocol (ICMP/UDP/TCP) and destination port to be used
 - Refer to the manpages for its options
 - Example:
 - **hping3 --ttl 1 --traceroute --destport 80 --syn www.fhv.at**
 - ttl 1** -> Start with time-to-live 1
 - traceroute** -> Increment ttl for subsequent attempts
 - destport 80** -> Use destination port 80
 - syn** -> Set the SYN flag in the probes
- ◆ **After scanning** the network structure you **know one possible network structure**
 - Of course there are still many uncertainties with this structure and it's only a small part of a big network.
 - It is a beginning and further analysis will allow to refine the structure

- ◆ Beyond determining the network structure, **searching for hosts in the individual networks** is an important task
 - We have already accumulated a host list when performing DNS queries during footprinting, but not all hosts have DNS entries
 - The result from searching for hosts can again be used to refine the network structure by performing traceroute / hping3
- ◆ The primary tools used for host searching are **fping** and **nmap**
 - **fping**
 - Is very similar to ping, but allows "pinging" entire networks
 - **nmap**
 - Has many more scanning options than fping and can therefore perform successful host searches where fping cannot
 - **Zenmap**, a graphical nmap user interface

- ◆ Performing a **host search in an entire network** with **fping**

```
root@debian:~# fping -a -A -n -g 193.170.2.0/24
router.nat.uclv.net (193.170.2.1)
router-ir-1.nat.uclv.net (193.170.2.33)
ICMP Host Unreachable from 193.171.158.11 for ICMP Echo sent to 193.170.2.40 (193.170.2.40)
ICMP Host Unreachable from 193.171.158.9 for ICMP Echo sent to 193.170.2.45 (193.170.2.45)
router-vpn.uclv.net (193.170.2.49)
vpn.fhv.at (193.170.2.52)
router-er-2.nat.uclv.net (193.170.2.57)
nat1-er-2.nat.uclv.net (193.170.2.58)
nat2-er-2.nat.uclv.net (193.170.2.59)
ICMP Host Unreachable from 193.171.158.11 for ICMP Echo sent to 193.170.2.66 (193.170.2.66)
ICMP Host Unreachable from 193.171.158.9 for ICMP Echo sent to 193.170.2.76 (193.170.2.76)
```

- **fping** Options

- a -> Show systems that are alive (reachable)
 - A -> Display (sort) targets by IP address rather than by DNS entry
 - n -> Perform DNS lookup to display hostnames
 - g -> Specifies the target list in the following value

- Displays both **hostnames** and **IP addresses** of found hosts

- ◆ **fping** (just like ping) has its **limitations**

- It works using **ICMP ECHO** messages
 - If there's a firewall blocking the probes, no result will be found

- ◆ So let's use **nmap** to perform a scan that is not (only) based on ICMP
 - Scanning can also be done by trying to **establish TCP connections** to ports that are often available (and not blocked) from outside, e.g. ssh or web
- ◆ **nmap scan** by trying to connect to **ports 22 and 80**

```
root@debian:~# nmap -sP -PS22,80 193.170.2.0/24

Starting Nmap 5.00 ( http://nmap.org ) at 2012-02-15 15:14 CET
Host router.nat.uclv.net (193.170.2.1) is up (0.0041s latency).
Host router-ir-1.nat.uclv.net (193.170.2.33) is up (1.0s latency).
Host 193.170.2.39 is up (1.0s latency).
Host router-vpn.uclv.net (193.170.2.49) is up (0.0031s latency).
Host router-er-2.nat.uclv.net (193.170.2.57) is up (0.0020s latency).
Nmap done: 256 IP addresses (5 hosts up) scanned in 21.15 seconds
```

- So there are indeed (at least) **five hosts available!**

- ◆ Once hosts have been discovered, the next question to answer is **what services are running on them**
- ◆ The tool to perform this is a port scanner and the most popular and powerful scanner is **nmap**
- ◆ **nmap can do** the following
 - Host scanning (as we have done before)
 - Various methods of TCP scanning (TCP connect, SYN, ACK, FIN, NUL, XMAS scan ...) and UDP scans
 - OS and software version guessing
- ◆ **Which hosts** to scan?
 - Depends on the time and effort you want to invest
 - Go for the targets that are likely to be valuable to be exploited (e.g. web server, mail server etc.)
 - "Normal" user computers may be interesting too, as they are often less well maintained (and may provide access to further systems)

- ◆ Let's start with a **TCP scan** (SYN scan as root) of www.fhv.at
 - -PN is needed when pings are blocked
 - No port range specified: test 1000 "typical" ports

- ◆ Interpretation
 - Only one port (HTTP) is **open**
 - All other ports are somewhere **filtered** by a firewall (no reply)
 - Ports that reply with a TCP RST would be marked **closed**

Scanning – Port Scanning (3)

- ◆ nmap can also be used to detect the **OS and software versions** of the installed services
 - This is done by looking for banners, TCP sequence number analysis etc.
 - Using the **-O** and **-sV** options (or **-A**, which combines them)

```
Starting Nmap 5.00 ( http://nmap.org ) at 2012-02-15 15:43 CET
Interesting ports on web.uclv.net (193.170.2.230):
PORT      STATE SERVICE VERSION
80/tcp    open  http      Apache httpd 2.2.21 ((FreeBSD) mod_ssl/2.2.21 OpenSSL/0.9.8
q DRIV/2)
|_ robots.txt: has 2 disallowed entries
|_ /*sendto_form$ /*folder_factories$
|_ html-title: FHV Portal &mdash; Fachhochschule Vorarlberg
Warning: OSScan results may be unreliable because we could not find at least 1 o
pen and 1 closed port
Device type: general purpose|storage-misc
Running (JUST GUESSING) : Apple Mac OS X 10.5.X (98%), BlueArc embedded (93%)
Aggressive OS guesses: Apple Mac OS X 10.5.5 (Leopard) (98%), BlueArc Titan 2100
NAS device (93%)
No exact OS matches for host (test conditions non-ideal).

TRACEROUTE (using port 80/tcp)
HOP RTT ADDRESS
1 0.17 192.168.23.2
2 1.08 web.uclv.net (193.170.2.230)

OS and Service detection performed. Please report any incorrect results at http:
//nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 14.40 seconds
```

- ◆ Manual methods are also well suited to determine software versions
 - By, e.g. using **telnet**, **netcat** or **openssl** (for SSL/TLS communications)

```
root@debian:~# telnet www.fhv.at 80
Trying 193.170.2.230...
Connected to web.ucbv.net.
Escape character is '^]'.
GET / HTTP/1.0

HTTP/1.1 302 Found
Date: Wed, 15 Feb 2012 15:47:59 GMT
Server: Apache/2.2.21 (FreeBSD) mod_ssl/2.2.21 OpenSSL/0.9.8q DAV/2
Location: http://www.fhv.at/
Content-Length: 317
Connection: close
Content-Type: text/html; charset=iso-8859-1
```

```
root@debian:~# openssl s_client -connect www.fhv.at:443_
GET / HTTP/1.0

HTTP/1.1 401 Unauthorized
Date: Wed, 15 Feb 2012 15:53:29 GMT
Server: Zope/(Zope 2.9.4-final, python 2.4.3, linux2) ZServer/1.1
Bobo-Exception-Line: 687
Content-Length: 268
Bobo-Exception-Value: See the server error log for details
Content-Type: text/html; charset=iso-8859-15
Bobo-Exception-Type: Unauthorized
Bobo-Exception-File: HTTPResponse.py
WWW-Authenticate: basic realm="FHV-Campus"
Connection: close
```

- ◆ **nmap** and **banner grabbing** help to identify possible vulnerabilities
 - But the **interpretation** of the results and **attempts to exploit** vulnerabilities are left to the attacker/analyst
- ◆ **Vulnerability Scanners** go further
 - They first also perform port scans and try to detect software versions
 - In addition, they contain a large **database of known vulnerabilities** of specific software versions and can therefore help to interpret the results
 - They also attempt to **automatically exploit some vulnerabilities** (e.g. try default passwords)
- ◆ Vulnerabilities Scanners are **powerful tools**, but
 - Their database of known vulnerabilities must be **constantly updated**
 - Often produce **false positives** (e.g. identifying the wrong software version and drawing wrong conclusions)
 - The result therefore still require manual interpretation and verification
 - They are usually limited to detecting publicly known vulnerabilities and misconfigurations

- ◆ The most popular general vulnerability scanner is **Nessus**
 - "General" in the sense that it tests at a **wide range of layers**
 - From OS vulnerabilities to server application vulnerabilities

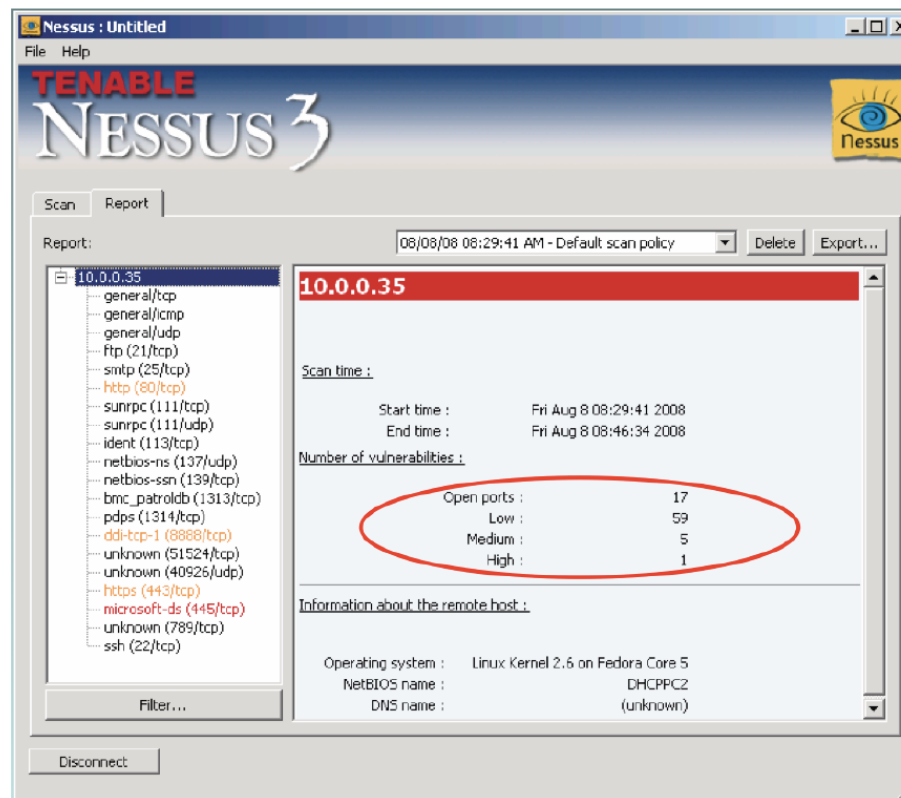
- ◆ The vulnerability tests in Nessus are called **plugins**
 - There are more than **10'000 official plugins** (distributed with Nessus) available
 - It's also possible to write own plugins
 - Nessus can be configured to **auto-update** its plugins over the internet

- ◆ There's a trend toward **commercialization**
 - Maintained by **Tenable Network Security**
 - Was originally free and open source
 - The free version can only be used to scan own systems (e.g. at home) but not to offer commercial services

- ◆ Nessus is a **client/server application**
 - Both components are available for a wide range of OS
- ◆ The **actual scanner is the server** and is reached through TCP port 1241
 - **Accounts** (username/password) for client-users must be set up on the server
 - It is possible to connect through SSL/TLS, so the Nessus server can securely be used from anywhere
- ◆ **Clients connect to the server** and configure and initiate scans
 - Usually, **graphical mode** is used but command-line is also available
 - Allows to define which plugins to use in a fine-granular way
 - Present results and generate reports for further analysis

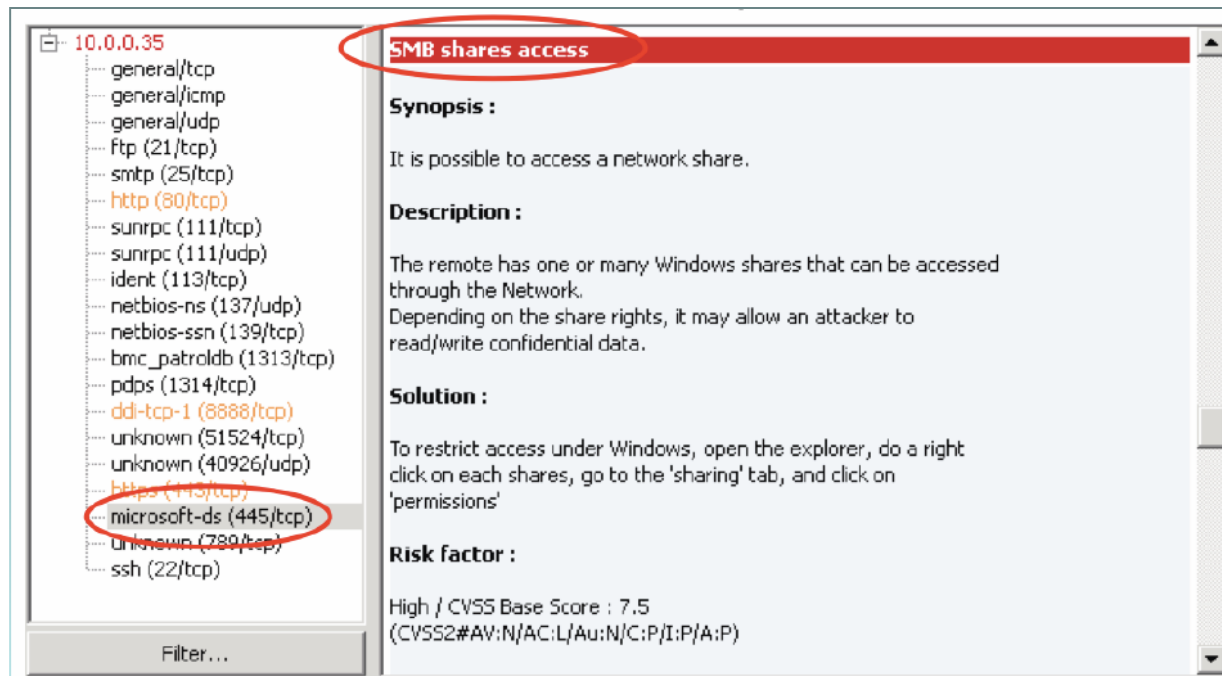
Scanning – Vulnerability Scanning (4)

- ◆ A **full Nessus scan** (all Plugins are enabled) of a not specifically hardened Linux host



Scanning – Vulnerability Scanning (5)

- ◆ Nessus provides **detailed information** about the problems detected
- ◆ **High risk example**



- ◆ Note: for Nessus, this is a **high risk**, but it may be a **false positive**
 - If one accidentally allows share access, it is indeed a high risk
 - If share access is purposely allowed, it's a false positive

Scanning – Vulnerability Scanning (6)

◆ Medium risk example



The screenshot shows a list of services on the left, with 'ddi-tcp-1 (8888/tcp)' highlighted. The right pane shows the details for this service, titled 'Weak Supported SSL Ciphers Suites'.

Weak Supported SSL Ciphers Suites

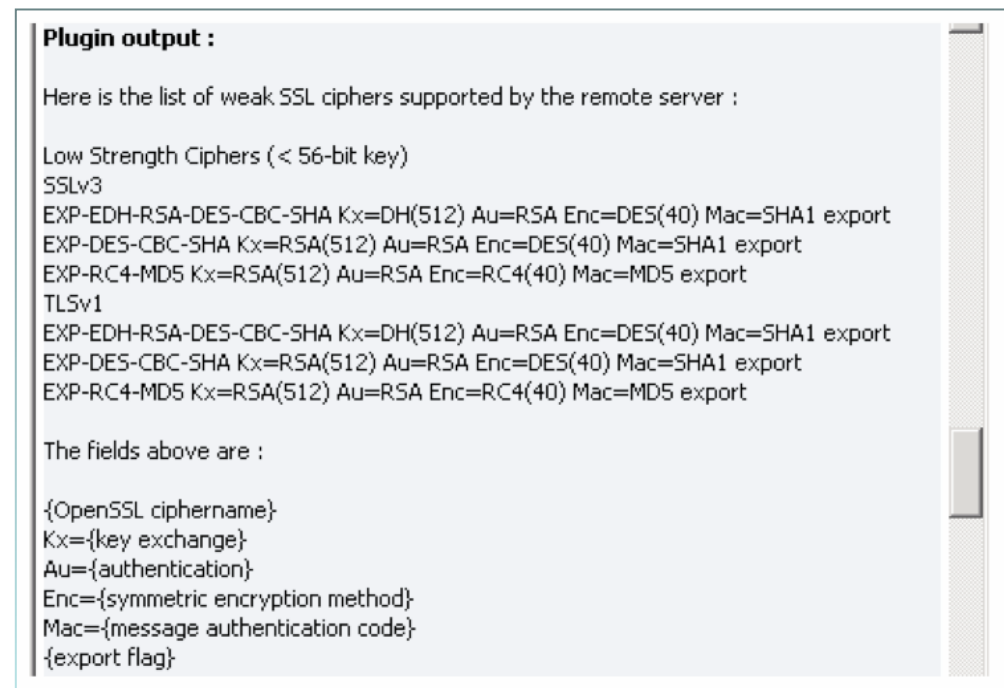
Synopsis :

The remote service supports the use of weak SSL ciphers.

Description :

The remote host supports the use of SSL ciphers that offer either weak encryption or no encryption at all.

- ◆ In this case, this is a **true positive** as ciphers with 40-bit keys are supported
- ◆ **Medium risk is a reasonable classification** because it is not something an attacker can easily exploit



Plugin output :

Here is the list of weak SSL ciphers supported by the remote server :

Low Strength Ciphers (< 56-bit key)

SSLv3

EXP-EDH-RSA-DES-CBC-SHA Kx=DH(512) Au=RSA Enc=DES(40) Mac=SHA1 export

EXP-DES-CBC-SHA Kx=RSA(512) Au=RSA Enc=DES(40) Mac=SHA1 export

EXP-RC4-MD5 Kx=RSA(512) Au=RSA Enc=RC4(40) Mac=MD5 export

TLSv1

EXP-EDH-RSA-DES-CBC-SHA Kx=DH(512) Au=RSA Enc=DES(40) Mac=SHA1 export

EXP-DES-CBC-SHA Kx=RSA(512) Au=RSA Enc=DES(40) Mac=SHA1 export

EXP-RC4-MD5 Kx=RSA(512) Au=RSA Enc=RC4(40) Mac=MD5 export

The fields above are :

{OpenSSL ciphername}

Kx={key exchange}

Au={authentication}

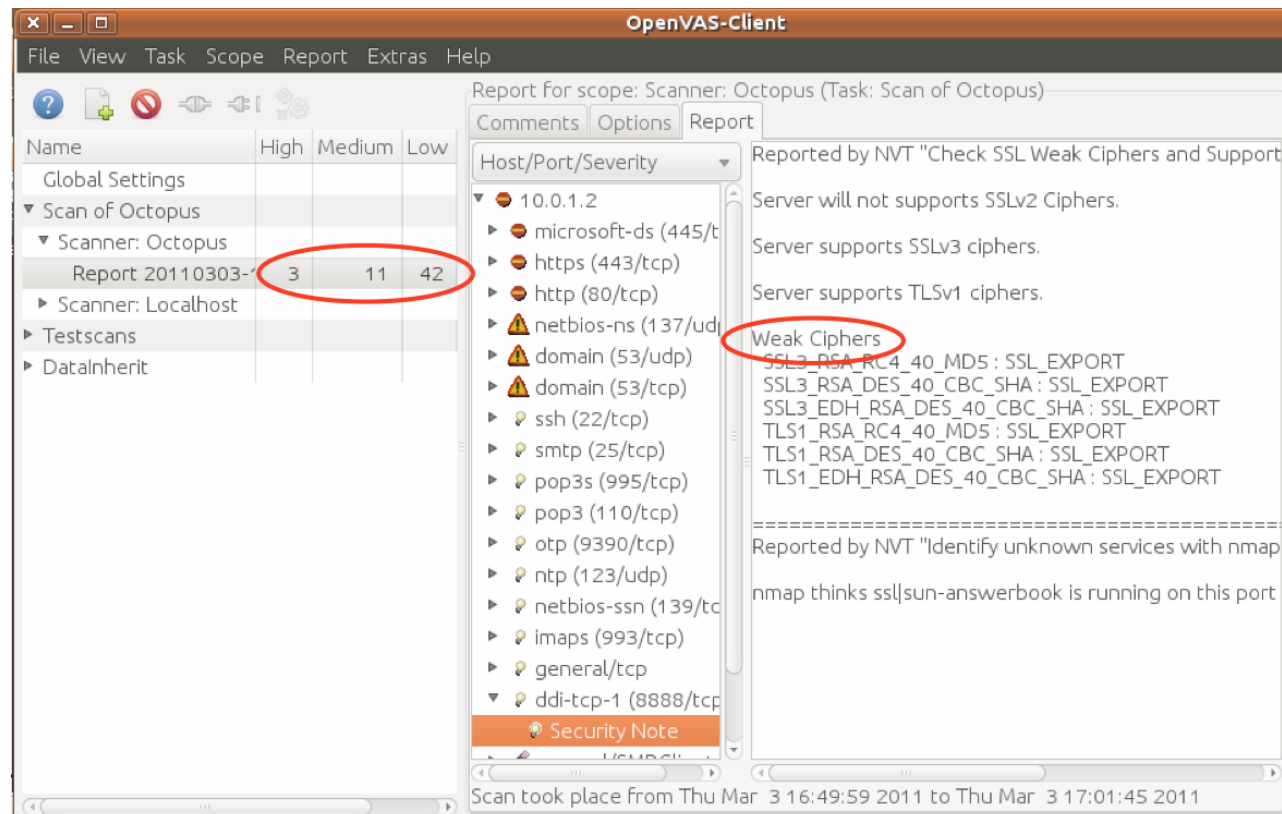
Enc={symmetric encryption method}

Mac={message authentication code}

{export flag}

Scanning – Vulnerability Scanning (7)

- ◆ A free, open source alternative to Nessus: **OpenVAS**
 - Provides very similar results to Nessus



- ◆ Scanning serves to **analyze the network structure and the individual hosts in detail**
- ◆ After scanning, you know the **following information**
 - Parts or all of the network structure
 - Hosts that are reachable from your location
- ◆ Of a **subset of all hosts** (or all hosts if the analyzed environment is small) you know more detailed information
 - Operating system
 - Available services (that are visible from your location)
 - Software versions of the services
 - Potential vulnerabilities that may be exploited

ANALYSIS OF SCANNING RESULTS

- ◆ After "Footprinting and Scanning", a large number of **host, services and even potential vulnerabilities** are known
- ◆ The goal of this phase is to **identify the systems that are interesting to be analyzed further**, i.e. that one attempts to compromise
- ◆ Trying to **compromise** every possible system is usually not an option, so focusing on some systems is important
- ◆ In practice – especially with large environments – this may be a **multistep process**
 - Start with the most promising systems and try to compromise them
 - Depending on these results, further system may have to be considered
 - It can also be that compromising a systems provides access to further, previously inaccessible systems, and it may then be reasonable to analyze/scan these systems as well and so on ...

.....

What targets are interesting to compromise?

- ◆ Any host where Nessus/OpenVAS reported significant problems, e.g.
 - Configuration flaws (e.g. anonymous access to an FTP server)
 - Any known vulnerabilities (e.g. an unpatched windows system that allows remote administrator access)
 - ◆ Any system that is of "high value"
 - Web (application) servers that provide access to valuable data
 - ◆ Entry points into otherwise inaccessible networks
 - A not-so-important host, that is maybe less well protected, but that allows – when compromised – accessing further systems
 - ◆ ...
 - ◆ Again, this depends very much on the available time and the task you want to complete or have been assigned
-

- ◆ One should also consult **publicly available vulnerability databases** to check for further known vulnerabilities in the detected systems
 - **Vulnerability scanners** may have reported some known vulnerabilities, but they can only detect a vulnerability if a corresponding plugin exists
- ◆ The most prominent is **Common Vulnerabilities and Exposures (CVE)**
 - Collects **known security vulnerabilities**
 - Assigns each with a unique number, e.g. **CVE-2006-0067**, consisting of the year (2006) and a vulnerability "number" (0067) within that year
 - "Candidate" vulnerabilities get the prefix **CAN**, meaning they are under review for inclusion in the list
 - Vulnerability scanners usually report the CVE number (if it exists) of a known vulnerability – and it makes sense to **verify them manually** (possibility of false positives)
- ◆ Other options: mailing lists
 - Bugtraq: <http://www.securityfocus.com>
 - ...

Analysis of Scanning Results - CVE

- ◆ Available at <http://cve.mitre.org>
- ◆ Provides option to **search** for specific software and error types
- ◆ And delivers **detailed information** about corresponding vulnerabilities

CVE and CCE Vulnerability Database Advanced Search ([Basic Search](#))

Vulnerability Criteria

☒ **Software Flaws (CVE)**

☐ **Misconfigurations (CCE), under development**

CVE Identifier:

Keyword (text search):

Category (CWE):

Search Results ([Refine Search](#))

There is one matching record. Displaying match **1** of **1**.

CVE-2009-3094

Summary: The ap_proxy_ftp_handler function in modules/proxy/proxy_ftp.c in the mod_proxy_ftp module in the Apache HTTP Server 2.0.63 and 2.2.13 allows remote FTP servers to cause a denial of service (NULL pointer dereference and child process crash) via a malformed reply to an EPSV command.

Published: 09/08/2009

CVSS Severity: 2.6 (LOW)

- ♦ The results of this analysis is a set of **systems and services that one attempts to compromise** in the next step
 - For some of these systems, vulnerabilities have already been discovered (esp. well-known vulnerabilities and configuration flaws)
- ♦ Information about known-vulnerabilities can stem from **different sources**
 - Vulnerability scanners
 - Manual searches in public databases
 - Mailing lists
- ♦ **Prioritization of targets** is important
 - Which targets are **valuable** to compromise?
 - What is the estimated **effort** for a target to successfully compromising it (especially compared to the "value" of the target)
 - Which targets are prioritized according to my task as a tester or attacker?

FINDING AND EXPLOITING VULNERABILITIES

- ◆ The goal of this phase is to **compromise systems**
 - By using the already found **well-known vulnerabilities**
 - And finding **further (unknown) vulnerabilities**
 - And **exploiting** them

- ◆ The **thoroughness** of this phase again depends on the available time and the goals of the task
 - Sometimes, one only focuses on **known vulnerabilities** and in other cases (esp. with web application penetration tests), lots of effort is spent to uncover unknown vulnerabilities
 - Sometimes, it's enough to **identify a known vulnerability** and tell the client "what could be done" (without actual exploitation)
 - In other cases, a **proof-of-concept exploit** is used or developed to show the practical exploitability of a vulnerability
 - And sometimes, "**realistic exploits**" are presented

How to find **unknown vulnerabilities**?

- ◆ **Source Code Analysis**

- Very time-consuming if done manually, but may reveal detailed information about vulnerabilities

- ◆ Use a **vulnerability scanner** that targets specific types of applications

- Unlike Nessus/OpenVAS, they may find unknown vulnerabilities
- Often produce large numbers of false positives
- Popular to assess web applications

- ◆ **Buffer-Overflow brute force** testing tools

- Send long strings to server applications (e.g. parameters in a HTTP request)
- If the server crashes, a buffer overflow was likely found

- ◆ **Manual interaction** with the target application

- Very typical for web applications (hands-on assessment)
- Can produce very good quality testing – provided the tester is skilled

Exploiting vulnerabilities is possible in **multiple ways**

- ◆ For some basic configuration flaws, verification is usually **easy** (e.g. log into a service using the default password)
- ◆ Similarly, there are pre-fabricated **proof-of-concept exploits** available for many known vulnerabilities (e.g. unpatched systems)
 - E.g. Metasploit, <http://metasploit.com>
- ◆ Exploitation of detected (unknown) buffer overflow vulnerabilities is often **very difficult** without at least a debugable version of the software
- ◆ With **web applications**, **exploitation is often possible**, but requires significant skills with respect to web technologies
- ◆ ...

- ◆ The **goal of security testing** is to analyze an environment and to uncover as many security-relevant problems as possible
 - Fixing the identified problems should make the environment more secure
- ◆ One prominent type of security test is a penetration test, **which consists of several phases**
 1. **Preparation phase**
 - define scope
 2. **Footprinting**
 - collecting relevant information about the target environment
 3. **Scanning**
 - Examine the target networks and hosts in more detail
 4. **Analysis of scanning results**
 - Identify the systems that one will attempt to compromise during the following phase
 5. **Finding and exploiting vulnerabilities**
 - Identify vulnerable systems and demonstrate proof-of-concept or „real“ exploits
 6. **Reporting**
 - Prepare a written report and an oral presentation, including concrete recommendations